Datenschutz

Prof. Dr. Dominik Schoop, Datenschutzbeauftragter

5. November 2018

Inhaltsverzeichnis

1. Vorstellung
2. Datenschutzbeauftragter
    - Stellung
    - Aufgaben
3. Datenschutz als Grundrecht
4. Normen zum Datenschutz
5. EU-Datenschutz-Grundverordnung
    - Begriffe
    - Grundsätze des Datenschutzes
6. Verantwortlicher
7. Verantwortung der Verantwortlichen
8. Pflichten und Betroffenenrechte
9. Dokumentationspflicht: Verzeichnis von Verarbeitungstätigkeiten
10. Beispiele für datenschutzrechtliche Betrachtung
11. Auftragsdatenverarbeitung
12. Vorgehen und notwendige Dokumente

Prof. Dr. Dominik Schoop

Raum	F1.354
eMail	dominik.schoop@hs-esslingen.de
Telefon	0711/397-4467

- seit 2004 an der Hochschule in der Fakultät Graduate School
- auch aktiv in der Fakultät Informationstechnik
- Lehrthemen: IT-Sicherheit, Security Engineering, Automotive Safety and Security, Informationssysteme
- Auslandsbeauftragter IT
- seit 2012 Datenschutzbeauftragter der Hochschule Esslingen

Der/Die Datenschutzbeauftragte

- ist in allen wesentlichen datenschutzrechtlichen Fragen frühzeitig einzubinden,
- ist mit den notwendigen Ressourcen auszustatten,
- ist weisungsfrei und darf wegen des Amtes nicht benachteiligt werden,
- berichtet direkt der Behördenleitung,
- ist zur Wahrung der Geheimhaltung oder der Vertraulichkeit verpflichtet.

(DSGVO Art. 38)

Die Aufgaben eines/einer Datenschutzbeauftragten (DSGVO Art. 39):

- Unterrichtung und Beratung der Beschäftigten hinsichtlich ihrer Pflichten nach Datenschutzvorschriften
- Überwachung der Einhaltung von Datenschutzvorschriften sowie der Datenschutzstrategien der Verantwortlichen
- Zusammenarbeit mit der Aufsichtsbehörde (Landesbeauftragter für den Datenschutz)

Charta der Grundrechte der Europäischen Union (2000/C 364/01)

Art. 2: Recht auf Leben

> Jede Person hat das Recht auf Leben.

Charta der Grundrechte der Europäischen Union (2000/C 364/01)

Art. 2: Recht auf Leben

Jede Person hat das Recht auf Leben.

Art. 8: Schutz personenbezogener Daten

(1) Jede Person hat das Recht auf Schutz der sie betreffenden personenbezogenen Daten.

(2) Diese Daten dürfen nur nach Treu und Glauben für festgelegte Zwecke und mit Einwilligung der betroffenen Person oder auf einer sonstigen gesetzlich geregelten legitimen Grundlage verarbeitet werden. Jede Person hat das Recht, Auskunft über die sie betreffenden erhobenen Daten zu erhalten und die Berichtigung der Daten zu erwirken.

(3) Die Einhaltung dieser Vorschriften wird von einer unabhängigen Stelle überwacht.

„Freie Entfaltung der Persönlichkeit setzt unter den modernen Bedingungen der Datenverarbeitung den Schutz des Einzelnen gegen unbegrenzte Erhebung, Speicherung, Verwendung und Weitergabe seiner persönlichen Daten voraus. Dieser Schutz ist daher von dem Grundrecht des Art. 2 Abs. 1 in Verbindung mit Art. 1 Abs. 1 GG umfasst. Das Grundrecht gewährleistet insoweit die Befugnis des Einzelnen, grundsätzlich selbst über die Preisgabe und Verwendung seiner persönlichen Daten zu bestimmen.“ (Volkszählungsurteil 1983, BVerfGE 65, 1, C II 1 a)

„Die Würde des Menschen ist unantastbar. Sie zu achten und zu schützen ist Verpflichtung aller staatlichen Gewalt.“ (Art. 1 Abs. 1 GG)

„Jeder hat das Recht auf die freie Entfaltung seiner Persönlichkeit, soweit er nicht die Rechte anderer verletzt und nicht gegen die verfassungsmäßige Ordnung oder das Sittengesetz verstößt.“ (Art. 2. Abs. 1 GG, allgemeines Persönlichkeitsrecht)

zusammen mit Volkszählungsurteil

$\Rightarrow$ Recht auf informationelle Selbstbestimmung

EU-Datenschutz-Grundverordnung (EU-DSGVO)

- gilt ab 25.05.2018 unmittelbar.
- hat Anwendungsvorrang gegenüber nationalen Gesetzen.
- enthält Öffnungsklauseln: nationale Ausgestaltung möglich.
- regelt nicht alles: nationale Ausgestaltung notwendig.

Bundesdatenschutzgesetz (BDSG neu im DSAnpUG-EU)

- gilt nicht für Hochschulen.

Landesdatenschutzgesetz BW i.d.F.v. 12.6.2018 (LDSG BW)

- gilt für Landesbehörden.

Datenschutzregelungen in LHG, HSchulDSV, HZG, ...

- gelten weiterhin (Art. 6 Abs. 3 DSGVO).

Spezialregelungen in manchen Gesetzen (z.B. KunstUrhG, TMG)

- gelten nicht mehr, wenn sie DSGVO widersprechen.

Anwendungsbereich

EU-DSGVO gilt für

- die Verarbeitung personenbezogener Daten (Papier/Computer, manuell/automatisiert), die in einem Dateisystem gespeichert werden
- öffentlichen und nicht-öffentlichen Bereich, jedoch nicht für persönliche oder familiäre Tätigkeiten
- Verantwortliche mit Niederlassung in der EU unabhängig davon, ob die Verarbeitung in der EU stattfindet
- Personen, die sich in der EU befinden unabhängig davon, ob der Verantwortliche in der EU eine Niederlassung hat

(Art. 2 DSGVO)

personenbezogene Daten: alle Informationen, die sich auf eine identifizierte oder identifizierbare natürliche Person beziehen

personenbezogene Daten: alle Informationen, die sich auf eine identifizierte oder identifizierbare natürliche Person beziehen

identifizierbare Person: natürliche Person, die direkt oder indirekt, insbesondere mittels Zuordnung zu einer Kennung wie einem Namen, zu einer Kennnummer, zu Standortdaten, zu einer Online-Kennung oder zu einem oder mehreren besonderen Merkmalen, die Ausdruck der physischen, physiologischen, genetischen, psychischen, wirtschaftlichen, kulturellen oder sozialen Identität dieser natürlichen Person sind, identifiziert werden kann

personenbezogene Daten: alle Informationen, die sich auf eine identifizierte oder identifizierbare natürliche Person beziehen

identifizierbare Person: natürliche Person, die direkt oder indirekt, insbesondere mittels Zuordnung zu einer Kennung wie einem Namen, zu einer Kennnummer, zu Standortdaten, zu einer Online-Kennung oder zu einem oder mehreren besonderen Merkmalen, die Ausdruck der physischen, physiologischen, genetischen, psychischen, wirtschaftlichen, kulturellen oder sozialen Identität dieser natürlichen Person sind, identifiziert werden kann

Beispiele personenbezogener Daten:

Name, Matrikelnummer, Email-Adresse, Postadresse, Gehalt, Noten, Bewerbungsdaten, Gesundheitsdaten (ärztl. Atteste, ...), sexuelle Orientierung, Gewerkschaftszugehörigkeit, ...

Verarbeitung jeder Vorgang im Zusammenhang mit personenbezogenen Daten wie

- das Erheben,
- das Erfassen,
- die Organisation,
- das Ordnen,
- die Speicherung,
- die Anpassung oder Veränderung,
- das Auslesen,
- das Abfragen,
- die Verwendung,
- die Offenlegung durch Übermittlung, Verbreitung oder eine andere Form der Bereitstellung,
- den Abgleich oder die Verknüpfung,
- die Einschränkung,
- das Löschen oder die Vernichtung

pseudonyme Daten personenbezogene Daten, die nur durch zusätzliche, geschützte Daten einer Person zugeordnet werden können

anonyme Daten Daten, die nicht auf eine identifizierbare Person bezogen werden können (globale Anonymität)

anonyme Daten $\neq$ personenbezogene Daten

$\rightarrow$ nicht von DSGVO betroffen

besondere Kategorien personenbezogener Daten

- rassische und ethnische Herkunft
- politische Meinungen
- religiöse oder weltanschauliche Überzeugungen
- Gewerkschaftszugehörigkeit
- genetische Daten
- biometrische Daten
- Gesundheitsdaten (körperlich oder geistig, Dienstleistungen, ...)
- Daten zum Sexualleben oder der sexuellen Orientierung

Verantwortlicher: Person, Behörde, Einrichtung oder andere Stelle, die allein oder gemeinsam mit anderen über die Zwecke und Mittel der Verarbeitung von personenbezogenen Daten entscheidet

Verantwortlicher: Person, Behörde, Einrichtung oder andere Stelle, die allein oder gemeinsam mit anderen über die Zwecke und Mittel der Verarbeitung von personenbezogenen Daten entscheidet

Auftragsverarbeiter: Person, Behörde, Einrichtung oder andere Stelle, die personenbezogene Daten im Auftrag des Verantwortlichen verarbeitet

Empfänger: eine natürliche oder juristische Person, Behörde, Einrichtung oder andere Stelle, der personenbezogene Daten offengelegt werden, unabhängig davon, ob es sich bei ihr um einen Dritten handelt oder nicht

Dritter: Person, Behörde, Einrichtung oder andere Stelle, außer der betroffenen Person, dem Verantwortlichen, dem Auftragsverarbeiter und den Personen, die unter der unmittelbaren Verantwortung des Verantwortlichen oder des Auftragsverarbeiters befugt sind, die personenbezogenen Daten zu verarbeiten

Grundsätze nach Art. 5 DSGVO

1. Rechtmäßigkeit: Einwilligung, gesetzliche Grundlage, Vertrag, ...

Grundsätze nach Art. 5 DSGVO

1. Rechtmäßigkeit: Einwilligung, gesetzliche Grundlage, Vertrag, ...
2. Verarbeitung nach Treu und Glauben: redlich und anständig

Grundsätze nach Art. 5 DSGVO

1. Rechtmäßigkeit: Einwilligung, gesetzliche Grundlage, Vertrag, ...
2. Verarbeitung nach Treu und Glauben: redlich und anständig
3. Transparenz: Verarbeitung in für die betroffene Person nachvollziehbare Weise, d.h. Information für Betroffene

Grundsätze nach Art. 5 DSGVO

1. Rechtmäßigkeit: Einwilligung, gesetzliche Grundlage, Vertrag, ...
2. Verarbeitung nach Treu und Glauben: redlich und anständig
3. Transparenz: Verarbeitung in für die betroffene Person nachvollziehbare Weise, d.h. Information für Betroffene
4. Zweckbindung: Verarbeitung nur für festgelegte, eindeutige und legitime Zwecke

Grundsätze nach Art. 5 DSGVO

1. Rechtmäßigkeit: Einwilligung, gesetzliche Grundlage, Vertrag, ...
2. Verarbeitung nach Treu und Glauben: redlich und anständig
3. Transparenz: Verarbeitung in für die betroffene Person nachvollziehbare Weise, d.h. Information für Betroffene
4. Zweckbindung: Verarbeitung nur für festgelegte, eindeutige und legitime Zwecke
5. Datenminimierung: nur die notwendigen Daten

Grundsätze nach Art. 5 DSGVO

1. Rechtmäßigkeit: Einwilligung, gesetzliche Grundlage, Vertrag, ...
2. Verarbeitung nach Treu und Glauben: redlich und anständig
3. Transparenz: Verarbeitung in für die betroffene Person nachvollziehbare Weise, d.h. Information für Betroffene
4. Zweckbindung: Verarbeitung nur für festgelegte, eindeutige und legitime Zwecke
5. Datenminimierung: nur die notwendigen Daten
6. Richtigkeit: Daten sind immer sachlich korrekt

Grundsätze nach Art. 5 DSGVO

1. Rechtmäßigkeit: Einwilligung, gesetzliche Grundlage, Vertrag, ...
2. Verarbeitung nach Treu und Glauben: redlich und anständig
3. Transparenz: Verarbeitung in für die betroffene Person nachvollziehbare Weise, d.h. Information für Betroffene
4. Zweckbindung: Verarbeitung nur für festgelegte, eindeutige und legitime Zwecke
5. Datenminimierung: nur die notwendigen Daten
6. Richtigkeit: Daten sind immer sachlich korrekt
7. Speicherbegrenzung: Speicherung nur so lange wie nötig

Grundsätze nach Art. 5 DSGVO

1. Rechtmäßigkeit: Einwilligung, gesetzliche Grundlage, Vertrag, ...
2. Verarbeitung nach Treu und Glauben: redlich und anständig
3. Transparenz: Verarbeitung in für die betroffene Person nachvollziehbare Weise, d.h. Information für Betroffene
4. Zweckbindung: Verarbeitung nur für festgelegte, eindeutige und legitime Zwecke
5. Datenminimierung: nur die notwendigen Daten
6. Richtigkeit: Daten sind immer sachlich korrekt
7. Speicherbegrenzung: Speicherung nur so lange wie nötig
8. Rechenschaftspflicht: Der Verantwortliche ist für die Einhaltung der Grundsätze verantwortlich und muss deren Einhaltung nachweisen können. $\rightarrow$ Datenschutzmanagementsystem (DSMS) notwendig

Rechtmäßigkeit im Kontext Hochschule (Art. 6 (1)):

a) Einwilligung

b) zur Erfüllung eines Vertrages

c) zur Erfüllung der rechtlichen Verpflichtung des Verantwortlichen erforderlich

e) Wahrnehmung einer Aufgabe im öffentlichen Interesse
EU oder Staat muss Rechtsgrundlage schaffen (Art. 6 (3)) z.B. in LDSG, LHG, HZG, HSchulDSV, weitere Verordnungen, Satzungen, ...

f) berechtigtes Interessen des Verantwortlichen, sofern nicht die Interessen oder Grundrechte und Grundfreiheiten der betroffenen Person überwiegen (nicht für Behörde bei Erfüllung ihrer Aufgaben)

Einwilligung der betroffenen Person jede freiwillig für den bestimmten Fall, in informierter Weise und unmissverständlich abgegebene Willensbekundung in Form einer Erklärung oder einer sonstigen eindeutigen bestätigenden Handlung, mit der die betroffene Person zu verstehen gibt, dass sie mit der Verarbeitung der sie betreffenden personenbezogenen Daten einverstanden ist

Einwilligung

- muss nachgewiesen werden können.
- muss in verständlicher und leicht zugänglicher Form in einer klaren und einfachen Sprache so erfolgen, dass sie von den anderen Sachverhalten klar zu unterscheiden ist.
- kann jederzeit widerrufen werden (jedoch nicht rückwirkend); Widerruf so einfach wie Einwilligung
- Freiwilligkeit muss klar sein

Einwilligung im Hochschulkontext:

- Einwilligung sollte nicht notwendig sein.
- Wenn Dienstaufgabe dann gesetzliche Grundlage.
- Wenn keine gesetzliche Grundlage dann keine Dienstaufgabe.

Ausnahme Forschung: z.B. personenbezogene Umfragen

Rechtmäßigkeit im Kontext Hochschule (Art. 6 (1) i.V.m. Art. 6 (3))

LDSG § 4 Erforderlichkeit zur Erfüllung der in der Zuständigkeit der öffentlichen Stelle liegenden Aufgabe

Aufgabe der Hochschule:
Pflege und der Entwicklung der Wissenschaften und der Künste durch Forschung, Lehre, Studium und Weiterbildung (LHG § 2 (1))

z.B. Vorlesungsorganisation, Prüfungsorganisation, Prüfungen, Notenlisten, Praktikantenverwaltung, ...

Beispiele Spezialregelungen

HSchulDSV Daten von (zukünftigen) Studierenden

HZG dialogorientiertes Serviceverfahren (DoSV, Bewerbung)

LHG § 12 Kontaktdaten von Alumni, elektr. Hochschulausweis, Zeiterfassung, ...

Gesundheitsdaten personenbezogene Daten, die sich auf die körperliche oder geistige Gesundheit einer natürlichen Person, einschließlich der Erbringung von Gesundheitsdienstleistungen, beziehen und aus denen Informationen über deren Gesundheitszustand hervorgehen (Art. 4 DSGVO)

„[...] die Verarbeitung von [...] Gesundheitsdaten [...] ist untersagt.“ (Art. 9 (1) DSGVO)

Ausnahmen im Kontext Hochschule (Art. 9 (2)):

- Einwilligung
- Erforderlichkeit für Recht auf Sozialschutz

Ein Verantwortlicher ist eine *Person, Behörde, Einrichtung oder andere Stelle, die allein oder gemeinsam mit anderen über die Zwecke und Mittel der Verarbeitung von personenbezogenen Daten entscheidet*. (Art. 4 Ziff. 7)

Beispiele:

„Verfahren“	Verantwortlicher
Lehrevaluation	Rektorat
Dokumentenmanagementsystem	Kanzlerin
Noten in LSF	Studentische Abteilung
Hochschulausweis	RZ/TA
Berufungskommission	Dekan/in
BAföG-Antrag über Fakultätssekretariat	Dekan/in
Prüfungen	Professor/in
lokale Notenliste	Professor/in
Umfrage bei Abschlussarbeit	Professor/in
Forschungsprojekt	Professor/in

Der Verantwortliche

- setzt nach Risikoanalyse geeignete technische und organisatorische Maßnahmen (TOMs) um. (Art. 24)
  z.B.
  - Pseudonymisierung und Verschlüsselung
  - Maßnahmen zur Vertraulichkeit, Integrität, Verfügbarkeit und Belastbarkeit
  - Verfahren zur regelmäßigen Überprüfung (Art. 32)
- muss den Nachweis dafür erbringen können, dass die Verarbeitung gemäß dieser Verordnung erfolgt. (Art. 24)
- stellt sicher, dass ihnen unterstellte natürliche Personen, die Zugang zu personenbezogenen Daten haben, diese nur auf Anweisung des Verantwortlichen verarbeiten. (Art. 32)

- ausführliche Information der Betroffenen bei Erhebung bei der Betroffenen und bei Dritten (Art. 13, 14)
  - praktisch Inhalt des Verzeichnis der Verarbeitungstätigkeit (VVT)
  - Hinweis auf Widerspruchsrecht, Auskunftsrecht, Beschwerderecht

- ausführliche Information der Betroffenen bei Erhebung bei der Betroffenen und bei Dritten (Art. 13, 14)
  - praktisch Inhalt des Verzeichnis der Verarbeitungstätigkeit (VVT)
  - Hinweis auf Widerspruchsrecht, Auskunftsrecht, Beschwerderecht
- Widerspruchsrecht (Art. 21)
  - Betroffene darf Widerspruch gegen Verarbeitung einlegen (auch beim Zweck der wissenschaftlichen Forschung)
  - Hinweis in einer verständlichen und von anderen Informationen getrennten Form bei erster Kommunikation

- ausführliche Information der Betroffenen bei Erhebung bei der Betroffenen und bei Dritten (Art. 13, 14)
  - praktisch Inhalt des Verzeichnis der Verarbeitungstätigkeit (VVT)
  - Hinweis auf Widerspruchsrecht, Auskunftsrecht, Beschwerderecht
- Widerspruchsrecht (Art. 21)
  - Betroffene darf Widerspruch gegen Verarbeitung einlegen (auch beim Zweck der wissenschaftlichen Forschung)
  - Hinweis in einer verständlichen und von anderen Informationen getrennten Form bei erster Kommunikation
- Auskunftsrecht (Art. 15)
  - ob und welche personenbezogene Daten gespeichert werden
  - zusätzliche Informationen zur Verarbeitung
  - Kopie der personenbezogenen Daten in einem gängigen elektronischen Format (Art. 20)

- ausführliche Information der Betroffenen bei Erhebung bei der Betroffenen und bei Dritten (Art. 13, 14)
  - praktisch Inhalt des Verzeichnis der Verarbeitungstätigkeit (VVT)
  - Hinweis auf Widerspruchsrecht, Auskunftsrecht, Beschwerderecht
- Widerspruchsrecht (Art. 21)
  - Betroffene darf Widerspruch gegen Verarbeitung einlegen (auch beim Zweck der wissenschaftlichen Forschung)
  - Hinweis in einer verständlichen und von anderen Informationen getrennten Form bei erster Kommunikation
- Auskunftsrecht (Art. 15)
  - ob und welche personenbezogene Daten gespeichert werden
  - zusätzliche Informationen zur Verarbeitung
  - Kopie der personenbezogenen Daten in einem gängigen elektronischen Format (Art. 20)
- Beschwerderecht bei Aufsichtsbehörde

Dokumentationspflicht: Verzeichnis von Verarbeitungstätigkeiten

Verzeichnis von Verarbeitungstätigkeiten (VVT)
$\sim$ ehem. Verfahrensverzeichnis (VVZ)

Verfahren Menge von datenschutzrelevanten Prozessen mit inhaltlichem Zusammenhang (Geschäftsprozss)
Beispiele: Einschreibung neuer Studierender, das Zutrittssystem

Verzeichnis Dokumentation aller datenschutzrechtlich zu prüfenden Verfahren (Verarbeitungstätigkeiten) der Hochschule

Alle Verantwortlichen müssen das Verzeichnis für ihre Verarbeitungstätigkeiten führen.

Dokumentationspflicht: Verzeichnis von Verarbeitungstätigkeiten

Ein Verzeichnis von Verarbeitungstätigkeiten beinhaltet:

1. Namen und die Kontaktdaten des Verantwortlichen sowie eines Datenschutzbeauftragten
2. Zwecke der Verarbeitung (inkl. Rechtsgrundlage)
3. betroffene Personen
4. betroffene personenbezogene Daten
5. Empfänger
6. gegebenenfalls Übermittlungen von personenbezogenen Daten an ein Drittland oder an eine internationale Organisation
7. Fristen für die Löschung der Daten
8. eine allgemeine Beschreibung der technischen und organisatorischen Maßnahmen

1. Verfahren	Einladung von ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen zum Fakultätsfest

Beispiele für datenschutzrechtliche Betrachtung

1. Verfahren	Einladung von ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen zum Fakultätsfest
2. Verantwortlicher	Dekan/in der Fakultät

Beispiele für datenschutzrechtliche Betrachtung

1. Verfahren	Einladung von ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen zum Fakultätsfest
2. Verantwortlicher	Dekan/in der Fakultät
3. Daten	Adressen der ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen

Beispiele für datenschutzrechtliche Betrachtung

1. Verfahren	Einladung von ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen zum Fakultätsfest
2. Verantwortlicher	Dekan/in der Fakultät
3. Daten	Adressen der ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen
4. Betroffene	ehemalige Studierende, Mitarbeiterinnen und Professorinnen

Beispiele für datenschutzrechtliche Betrachtung

1. Verfahren	Einladung von ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen zum Fakultätsfest
2. Verantwortlicher	Dekan/in der Fakultät
3. Daten	Adressen der ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen
4. Betroffene	ehemalige Studierende, Mitarbeiterinnen und Professorinnen
5. Verarbeitung	Adressen speichern, Einladungsbriefe schicken

Beispiele für datenschutzrechtliche Betrachtung

1. Verfahren	Einladung von ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen zum Fakultätsfest
2. Verantwortlicher	Dekan/in der Fakultät
3. Daten	Adressen der ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen
4. Betroffene	ehemalige Studierende, Mitarbeiterinnen und Professorinnen
5. Verarbeitung	Adressen speichern, Einladungsbriefe schicken
6. Zweck	mit den ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen in Kontakt bleiben

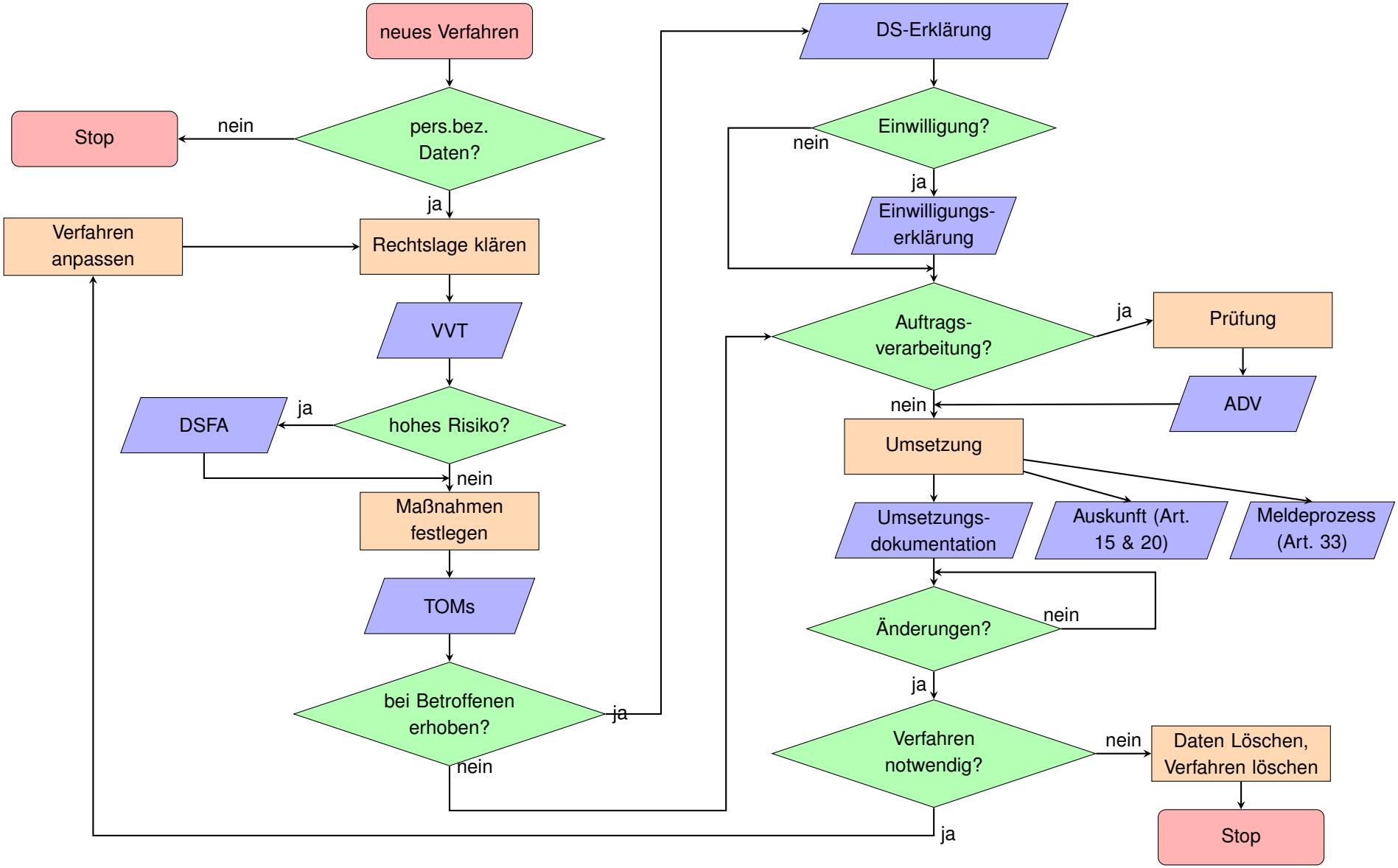
Beispiele für datenschutzrechtliche Betrachtung

1. Verfahren	Einladung von ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen zum Fakultätsfest
2. Verantwortlicher	Dekan/in der Fakultät
3. Daten	Adressen der ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen
4. Betroffene	ehemalige Studierende, Mitarbeiterinnen und Professorinnen
5. Verarbeitung	Adressen speichern, Einladungsbriefe schicken
6. Zweck	mit den ehemaligen Studierenden, Mitarbeiterinnen und Professorinnen in Kontakt bleiben
7. Rechtsgrundlage	LHG §12 (1): *[Die Hochschule darf] die personenbezogenen Daten ihrer ehemaligen Mitglieder und Angehörigen nutzen, soweit dies [...] zur Pflege der Verbindung mit den Betroffenen erforderlich ist und diese nicht widersprechen.*

- Verantwortlicher kann Auftragsverarbeiter mit Datenverarbeitung beauftragen
- Verantwortlicher benötigt hinreichende Garantien, dass der Auftragsverarbeiter geeignet ist
- Vertrag (ADV) mit vorgeschriebenem Inhalt notwendig (Unterschrift Hochschulleitung)
- Handlung nur auf dokumentierte Weisung
- Ketten von Unterauftragsnehmern möglich
- Auftragsverarbeiter führt eigenes Verzeichnis zur Verarbeitungstätigkeit (VVT)

Achtung bei Auftrag in USA: Patriot Act (USA), Widerspruch Einwilligung etc.
$\rightarrow$ Facebook etc. schwer rechtskonform nutzbar für *personenbezogene* Daten der Hochschule

Vorgehen und notwendige Dokumente



Schutzverletzungen, Sanktionen und Schadensersatz

- Bei Verletzung des Schutzes von personenbezogenen Daten
  - Meldung an die Aufsichtsbehörde innerhalb von 72 Stunden. (Art. 33)
  - Falls hohes Risiko für die persönliche Rechte und Freiheiten, so benachrichtigt der Verantwortliche die betroffene Person unverzüglich. (Art. 34)
- Aufsichtsbehörde kann Sanktionen festlegen
  - Geldbußen von bis zu 20.000.000 EUR oder im Fall eines Unternehmens von bis zu 4% seines gesamten weltweit erzielten Jahresumsatzes möglich (Art. 83)
    aber: Gegen öffentliche Stellen dürfen keine Geldbußen verhängt werden. (LDSG § 28)
- Freiheitsstrafe bis zu zwei Jahren oder Geldstrafe (LDSG § 29)
- Schadenersatz für materiellen oder immateriellen Schaden; jeder an einer Verarbeitung beteiligte Verantwortliche haftet (Art. 82)

Allgemeine Informationsquellen

- Vorlagen und Handreichungen unter `W:\projekt-DSB\staff`
- ZENDAS www.zendas.de (für berechtigte Hochschulen, aus dem Hochschulnetz erreichbar)
- Datenschutzstabsstelle des HSZ (Rechtsberatung für u.a. HAWs)
- Landesbeauftragter für den Datenschutz in BW
- Papiere der Datenschutzkonferenz (DSK)
- Gesellschaft für Datenschutz und Datensicherheit e.V. (GDD)
- Artikel-29-Gruppe (bzw. Nachfolger)